

Anhang A2 — Lastenheft-Auszug ****Projekt:**** Zero-Trust-Sicherheitskonzept mit GitHub-Integration ****Version:**** 1.0 ****Datum:**** 01.11.2026 ****Autor:**** Daniel Massa (Prüfling 615951)

--- ## 1. Projektbezeichnung Einführung eines Zero-Trust-Sicherheitskonzepts mit automatisierter Rechtevergabe und GitHub-basierter Workflow-Integration beim Verein zur Förderung der Berufsbildung e.V. (VFB), Ludwigsburg. --- ## 2. Ausgangssituation Der VFB verwaltet Zugriffsrechte derzeit manuell über E-Mail-Anträge. Dies führt zu: -

****Medienbrüche:**** 3–4 Stationen pro Antrag (Mitarbeiter → Vorgesetzter → IT-Admin → System) - ****Fehlerquote:**** 8–12 % Fehleinrichtungen durch Schreibfehler, Missverständnisse, fehlende Dokumentation - ****Bearbeitungszeit:**** Ø 2,5–3,5 Tage vom Eingang bis zur Umsetzung - ****Compliance-Lücken:**** Dezentrale Audit-Logs, keine revisionssichere Nachvollziehbarkeit - ****Sicherheitsrisiken:**** Überhöhte Rechte bei Austritern, keine Self-Service-Funktionen --- ## 3. Muss-Anforderungen (Funktional) | ID | Anforderung | Beschreibung | Priorität | Nachweis |

ID	Anforderung	Beschreibung	Priorität	Nachweis
MU-01	RBAC-Modell	Mind. 6 Rollen, 50+ Berechtigungen für GitHub-Org `vfb-bildung`	Muss	Rollenmatrix, Testfall TF01
MU-02	Self-Service-Antrag	Web-Portal zur Rollenbeantragung mit Validierung	Muss	Screenshot, TF02
MU-03	Genehmigungsworkflow	Automatische Weiterleitung an Vorgesetzten, 48h-Eskalation	Muss	TF03, TF04
MU-04	GitHub-Integration	Automatisierte Team-Zuordnung via GitHub API	Muss	YAML-Workflow, TF07
MU-05	Audit-Logging	Revisionssichere Protokollierung aller Rechteänderungen	Muss	TF09, Export
MU-06	Rechteentzug	Automatisierter Entzug bei Austritt/Rollenwechsel	Muss	TF08
MU-07	DSGVO-Konformität	Datenminimierung, Löschkonzept, TOM (Art. 32)	Muss	Checkliste A14
MU-08	Dokumentation	Vollständige Projektdokumentation (IHK-Vorgaben)	Muss	Abgabe

--- ## 4. Kann-Anforderungen (Funktional) | ID | Anforderung | Beschreibung | Priorität |

ID	Anforderung	Beschreibung	Priorität
KA-01	Compliance-Dashboard	Monitoring-UI für Audit-Logs, Anomalien	Kann
KA-02	Anomalieerkennung	KI-basierte Erkennung verdächtiger Rollenänderungen	Kann
KA-03	Secret-Scanning-Integration	Automatisches Scanning bei Code-Push	Kann
KA-04	Multi-Faktor-Auth	MFA für Admin-Aktionen im Portal	Kann

--- ## 5. Schnittstellen | Schnittstelle | System | Protokoll | Zweck |

Schnittstelle	System	Protokoll	Zweck
IF-01	GitHub Enterprise	REST API (HTTPS)	Team/Repo-Management, Audit-Log
IF-02	Azure AD / Entra ID	SAML 2.0 / OIDC	Single Sign-On, User-Attribute
IF-03	PostgreSQL	SQL (SSL)	Persistenz (User, Rollen, Audit-Log)
IF-04	GitHub Actions	Webhook / API	Workflow-Triggers, Status-Callbacks
IF-05	Export-Schnittstelle	REST (HTTPS)	CSV/JSON-Export für Audits

--- ## 6. Nicht-funktionale Anforderungen | Kategorie | Anforderung | Messkriterium |

Kategorie	Anforderung	Messkriterium
Performance	API-Antwortzeit	< 500 ms (p95) Lasttest 100 req/s
Verfügbarkeit	Uptime	99,5 % (außer geplante Wartung) Monitoring
Sicherheit	TLS 1.3, keine Secrets im Code	CodeQL, Secret-Scan
Datenschutz	DSGVO Art. 5, 25, 32 erfüllt	DPIA, Checkliste A14
Auditierbarkeit	Abdeckung aller Änderungen	100 % Testfall TF09
Wartbarkeit	Code Coverage	≥ 80 % (Kern) Jest/Supertest

--- ## 6. Abgrenzung (Out of Scope) - Änderungen an physischer Netzwerkinfrastruktur (Firewalls, VLANs) - Ablösung bestehender Identitätssysteme (AD,

Azure AD bleiben Lead) - Produktivrollout in allen Bereichen (nur Pilotphase 15 Nutzer) - Installation externer Cloud-IDPs (Okta, Auth0, etc.) --- ## 7. Qualitätsziele | Ziel | Metrik | Zielwert | |-----|-----|-----| | Bearbeitungszeit | Antrag → Genehmigung | < 4 Stunden (Soll: 3,2 Tage → < 4 h) | | Fehlerquote | Fehleinrichtungen / Monat | < 2 % (Soll: 10 % → < 2 %) | | Audit-Abdeckung | Protokollierte Änderungen | 100 % | | Testabdeckung | Unit/Integration Tests | ≥ 80 % (Kernmodule) | | Amortisation | Investition → Break-even | ≤ 3,5 Monate | --- ## 8. Rechtliche & Organisatorische Rahmenbedingungen - **DSGVO:** Art. 5 (Grundsätze), Art. 25 (Privacy by Design), Art. 32 (TOM) - **ISO 27001:** A.9 Zugriffskontrolle, A.12.4 Protokollierung, A.15 Lieferantenbeziehungen - **BSI Grundsatz:** SYS.1.2.3 Identitäts- und Berechtigungsmanagement - **IHK-Vorgaben:** 70 h Gesamtaufwand, Abgabe bis 01.11.2026, Eidesstattliche Erklärung --- ## 9. Stakeholder & Verantwortlichkeiten | Rolle | Name | Verantwortung | |-----|-----|-----| | Auftraggeber | Geschäftsführung VFB | Budget, Scope, Abnahme | | Projektleiter | Daniel Massa | Planung, Umsetzung, Doku | | IT-Administration | Thomas Zoller | Technische Umsetzung, Betrieb | | Datenschutzbeauftragter | Intern | DPIA, DSGVO-Prüfung, TOM-Freigabe | | Security-Consultant | Prof. Dr. Schulze (ext.) | Security-Review, Compliance-Validierung | | Endnutzer (Pilot) | 15 Mitarbeiter | Test, Feedback, Akzeptanz | --- ## 10. Terminplan (Meilensteine) | Meilenstein | Datum | Ergebnis | |-----|-----|-----| | M1: Ist-Analyse | 15.08.2026 | Anforderungsdokument | | M2: Konzeption | 30.08.2026 | Fachkonzept, Pflichtenheft | | M3: Architektur | 15.09.2026 | Zielarchitektur, Datenmodell | | M4: Prototyp | 10.10.2026 | Funktionsfähiger Prototyp | | M5: Test/Abnahme | 20.10.2026 | Testprotokoll, Abnahme | | M6: Fertigstellung | 25.10.2026 | Vollständige Doku | | M7: Korrektur | 31.10.2026 | Korrigierte Endfassung | | **M8: Abgabe IHK** | **01.11.2026** | **Eingereichte Projektarbeit** | --- ## 10. Änderungsmanagement Änderungen am Lastenheft bedürfen der schriftlichen Freigabe durch den Lenkungsausschuss (Auftraggeber, PL, IT-Admin, DSB). Dokumentiert in Kapitel 2.11 der Projektarbeit. --- *Ende Anhang A2. Vgl. Kapitel 3.2 der Projektarbeit.*